

IT Security

Chapter 1: Basics

Dr. Hong-Ngoc Tran

Prof. Dr.-Ing. Peter Ebinger

- copyrighted material -
- for VGU student use only -



Agenda

Introduction

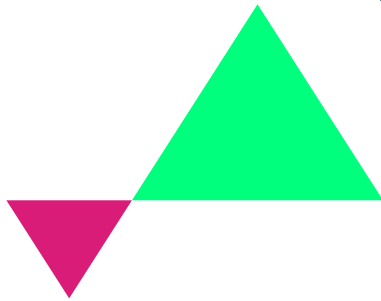
THE Communication Model of IT Security

Security Objectives and Attack Scenarios

Terms and Definitions

Privacy and Data Protection

Introduction



Motivation for Attackers

- Classic attackers
 - White hat: uncovering security gaps
 - Secret services: espionage, sabotage and surveillance
 - Companies: industrial espionage (cooperation with secret services)
- Developments in the last decade
 - Establishment of a highly professionalized shadow economy (black hat, contract hacking)
 - Publication of secret information (whistleblower)
 - Politically motivated attacks

Motivation for Attackers (cont.)

- Shadow economy
 - A lot of money can be made with successful attacks
 - Bitcoin mining
 - phishing attacks in the area of online banking
 - accessing credit card information (commercial credit fraud)
- In addition, there is an established black market for vulnerabilities of IT systems (exploits)

Attack types – Overview/Examples

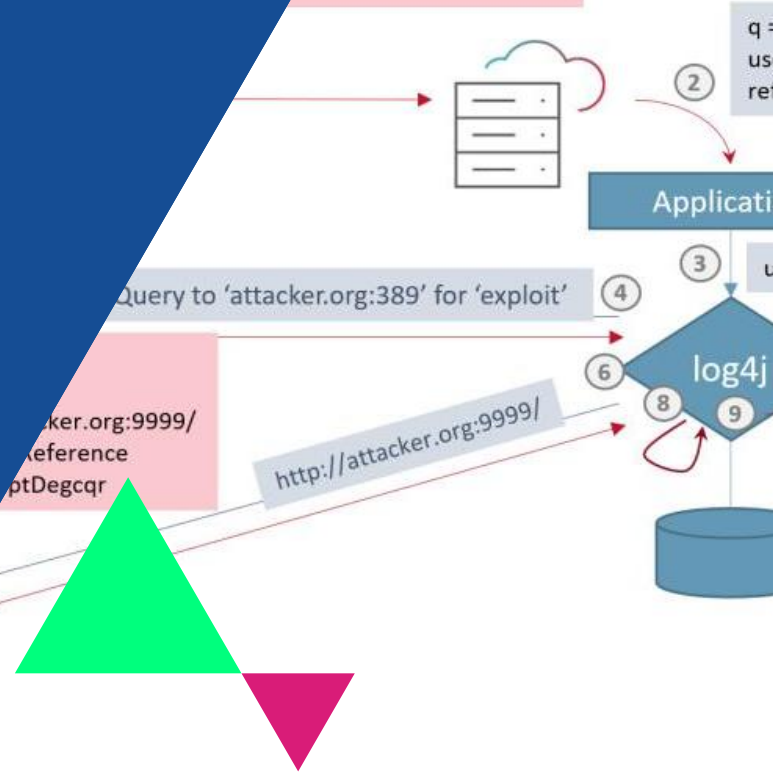
- **Untargeted attacks**, e.g.
 - mass emails for distributing viruses, worms and Trojans or launching phishing attacks
- **Targeted attacks**, e.g.
 - sabotage and espionage aimed at certain institutions (DDoS attacks on state infrastructures)
- **Advanced persistent threats (APT)**, e.g.
 - targeted sabotage on certain IT systems (Stuxnet)
 - certificate service provider (forgery of SSL certificates from the Dutch company DigiNotar in July 2011, this also affected the server certificate from google.com).
 - attack on computer system of the Democratic Party in the run-up to the US presidential election in 2016

Motivation: Security incidents

Example: Log4Shell

November / Dezember 2021:

A vulnerability has been discovered in the widely used logging software Log4j for Java
"Worst vulnerability ever."



Motivation: Security incidents

Example: Critical infrastructure

May 2021: Colonial Pipeline

Colonial, which operates a pipeline transporting petrol from Texas to New Jersey and the Midwestern United States, was disrupted by ransomware malware..



Motivation: Security incidents

Example: Facebook

April 2021: Data leak at Facebook

Cybercriminals stole data from 533 million Facebook users from Facebook servers

This was due to a misconfiguration in the function used by Facebook to import data from users' smartphones.

leak: details from 533 million users found on website for hackers

Users appear to be several years old but the leak stems from problem fixed in 2019



Facebook data leak: the personal details of 533 million users, including phone numbers and emails, have been found available on a website for hackers. Photograph: Dado Ruvić/Reuters

Details from more than 500 million **Facebook** users have been found available on a website for hackers.

The information appears to be several years old but it is another example of the vast amount of information collected by **Facebook and other social media companies** and the limits to how secure that information is.

Motivation: Security incidents

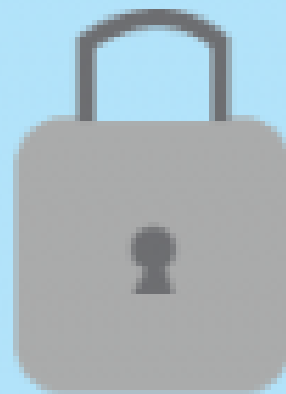
CMC Group Ransomware Attack (12 April 2025)

Attack on CMC Corporation, Vietnam,
by Crypto24 ransomware group

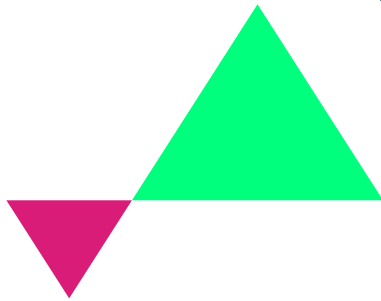
Attackers infiltrated CMC's private cloud environment, creating unauthorized administrator accounts.

2 TB of sensitive data, including tokens, databases, and website assets, were compromised.

Core services remained operational, the data breach triggered police investigation



THE Communication Model of IT Security



THE Communication Model of IT Security

- Actors: Alice, Bob and Mallory



Alice



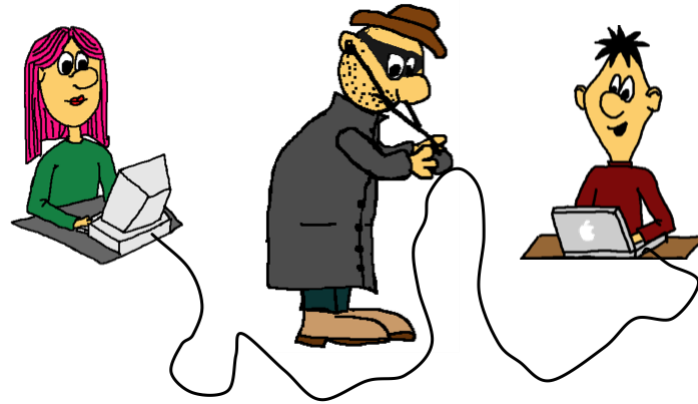
Bob



Mallory

THE Communication Model of IT Security

- Alice and Bob exchange messages over an insecure communication channel.
- Mallory tries everything to attack the communication between Alice and Bob.



THE Communication Model of IT Security

- Mallory's skills and capabilities:



Mallory can eavesdrop
on the line.
("Passive Attack")

THE Communication Model of IT Security

Mallory's skills and capabilities:

Mallory can
manipulate the line.
("Active Attack")



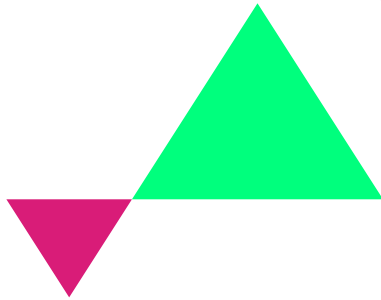
THE Communication Model of IT Security

Mallory's skills and capabilities:



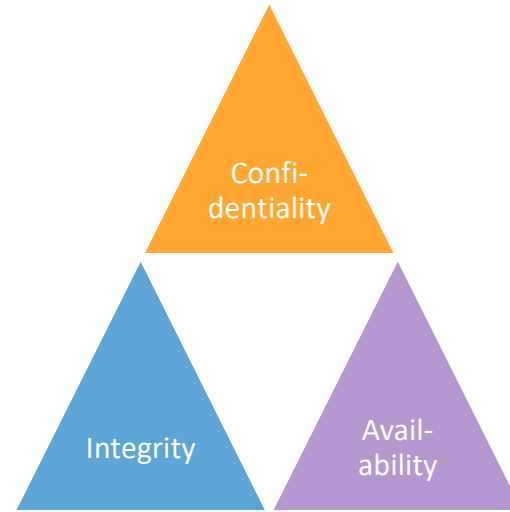
Mallory can cut the line.
("Active Attack")

Security Objectives and Attack Scenarios



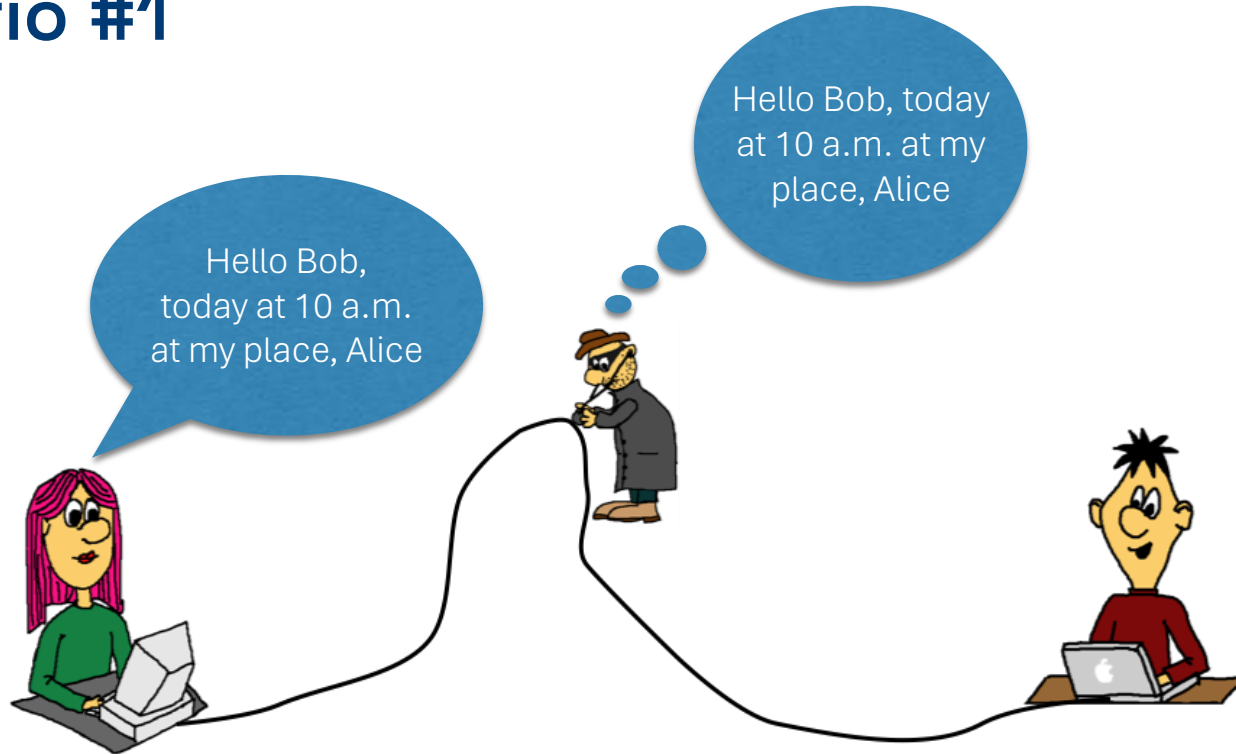
Security Objectives (aka Protection Goals)

- Principal security objectives :
 - Confidentiality
 - Integrity
 - Authenticity
 - Non-repudiation
 - Availability
- Protection goals regarding data protection
 - Privacy
 - Anonymity
 - Pseudonymity



CIA triad of core security objectives

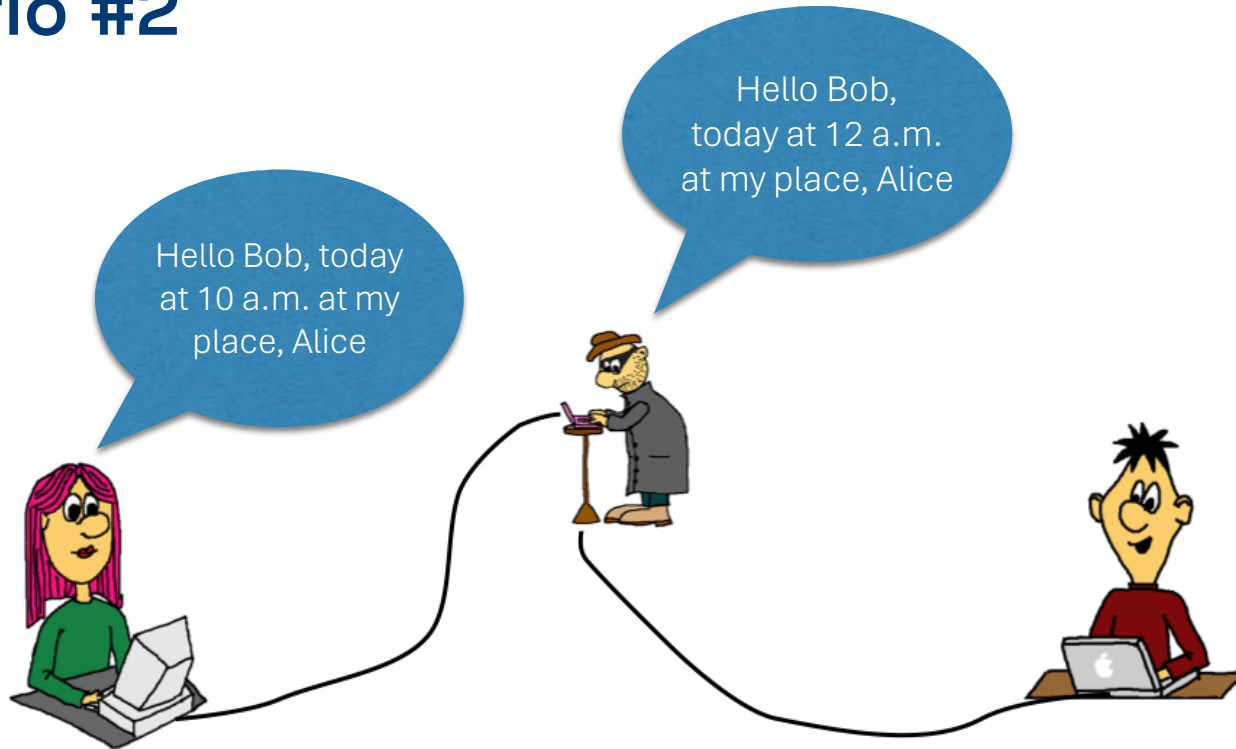
Scenario #1



Security Objective Confidentiality

- **Confidentiality** is intended to ensure that information is only accessible to authorized persons.
- Measures to implement the security objective confidentiality:
 - cryptographic encryption methods
 - delivery of documents by trustworthy couriers
 - physical protection (building security, room security)
 - access controls (suitable read rights for stored files/directories)

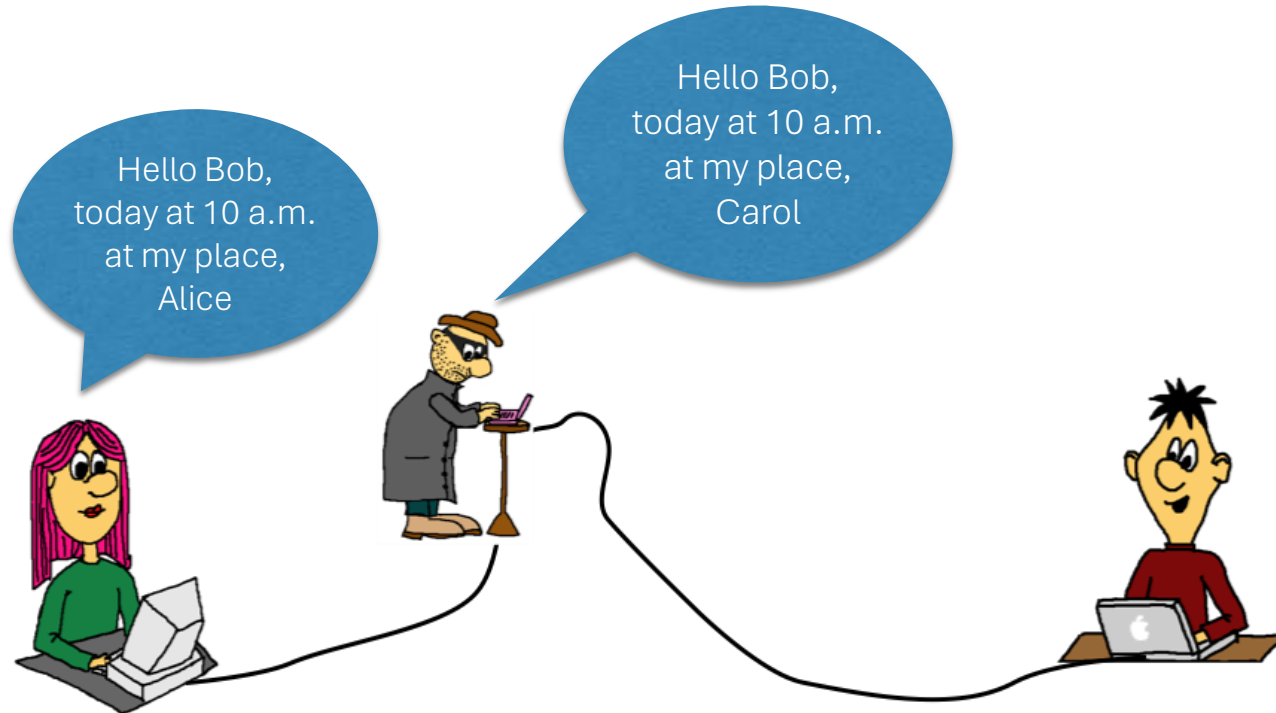
Scenario #2



Security Objective Integrity

- **Integrity** is understood to mean the completeness and correctness of the data for the period in which it was created, transmitted or stored by an authorized person.
 - This includes both intentional and unintentional changes, e.g., caused by technical errors.
- Measures to implement the security objective integrity:
 - cryptographic hash functions
 - safe storage of copies for later comparison with the original
 - access and admission rules

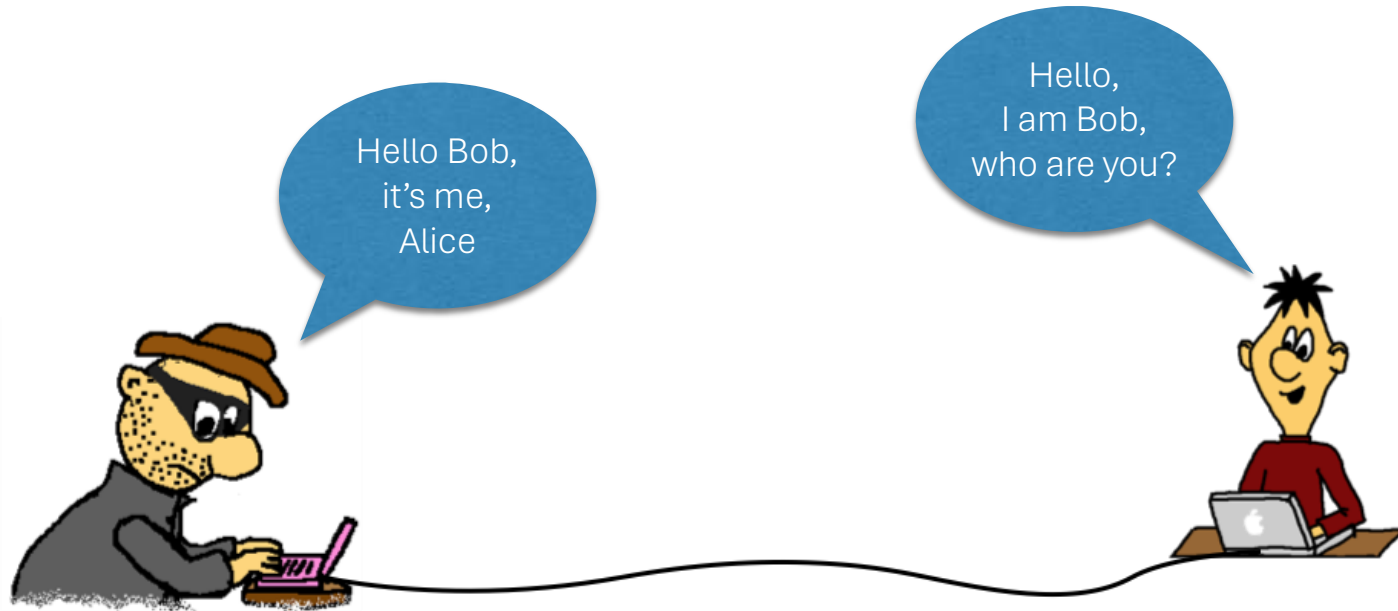
Scenario #3



Security Objective Data and Message Authenticity

- The **authenticity** of data/messages is guaranteed if the originator of the data can be clearly identified by the recipient and her/his authorship can be verified.
 - This also includes the integrity of the data.
- Measures to implement the security objective data/message authenticity:
 - electronic signatures
 - hand signing of a document
 - personal transfer of data

Scenario #4



Security Objective Subject (Instance) Authenticity

- A subject or object (instance) is called authentic if its authenticity and credibility can be checked using a clear identity and characteristic properties.
- Measures to implement the security objective subject (instance) authenticity:
 - username and password
 - challenge-response protocols
 - verification of identities based on official documents (passport, identity card)

Repudiation



Hi Bob, I would like
to order 100
kilograms of cheese
for my restaurant



Ok, no problem.
I will deliver it
to you
tomorrow.

The next day...

What do you mean? I
wanted 100 **grams**,
not 100 kilos!



Hi Alice, I brought
the cheese you
ordered!



Security Objective Non-Repudiation

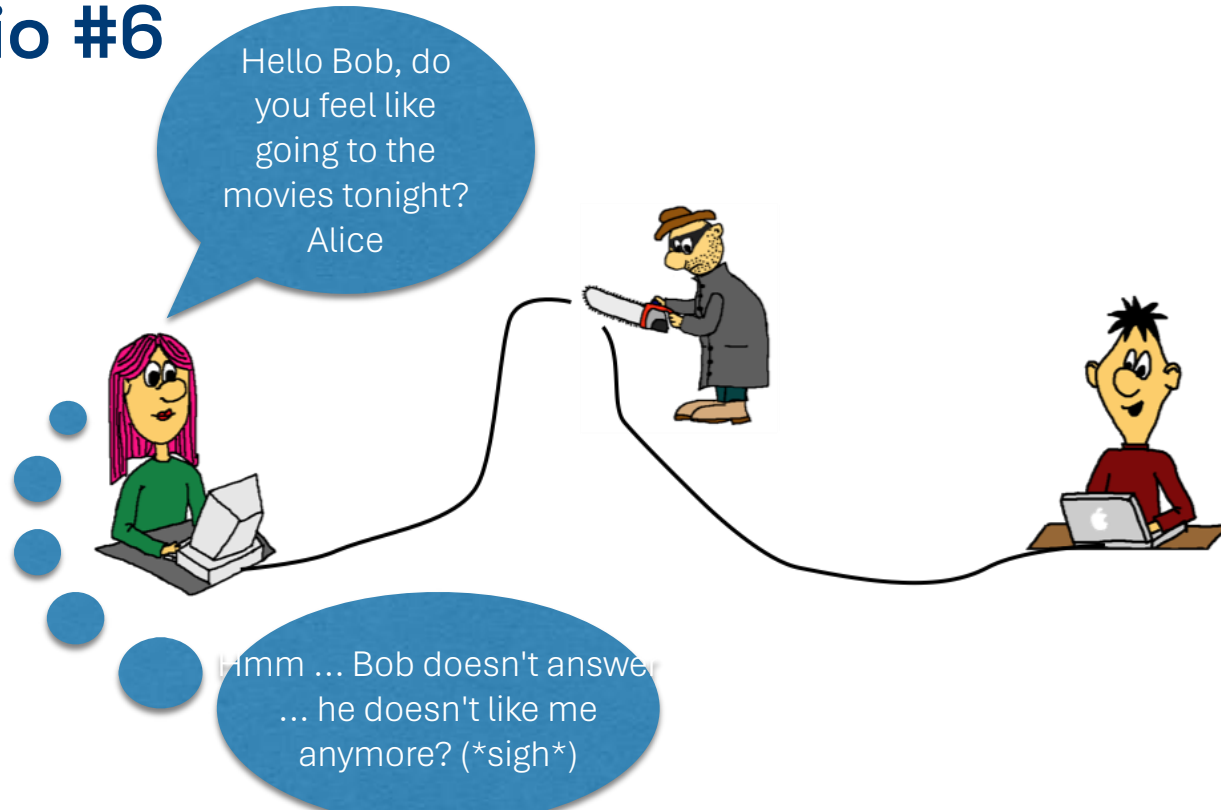
- **Non-repudiation** of data is guaranteed if the creator of the data cannot subsequently deny the generation (especially to third parties).
- Measures to implement the security objective non-repudiation:
 - electronic signatures
 - manual signature
 - use of trustworthy witnesses (e.g., notary)

Integrity vs. Authenticity vs. Non-Repudiation

- Delimitation and interrelation of these three terms.
 - Obviously, the following applies:
 - Authenticity follows from non-repudiation.
 - Integrity follows from authenticity.
- The reverse is generally not true:
 - Secure storage of a copy for later comparison ensures the integrity, but it cannot be used to determine who created the data.
 - In the case of a personal handover, the recipient knows who has received the data, but cannot prove this to a third party.

Non-Repudiation $\Rightarrow$ Authenticity
Authenticity $\Rightarrow$ Integrity

Scenario #6



Security Objective Availability

- An IT system grants **availability** if authorized subjects cannot be impaired in exercising their rights in an unauthorized manner.
- The availability is usually measured using the following formula:

$$Availability = \frac{Total Runtime - Downtime}{Total Runtime}$$

- Measures to implement availability
 - data backup
 - representation rules (e.g., for vacation replacement)
 - redundant design of components

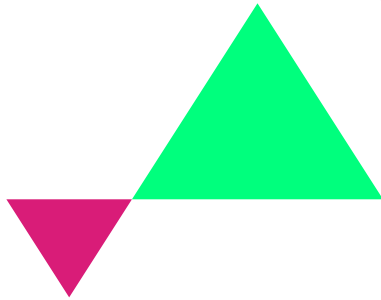
Example: Availability of Cloud Services

Cloud-Speicherdienste im Vergleich					
Ausgewählte Ergebnisse einer Untersuchung des Hasso-Plattner-Instituts (HPI)					
	Amazon S3	Google Cloud Storage	Hewlett Packard Cloud Object Storage	Rackspace Cloud Files	Windows Azure
Speicherkosten in US-Dollar pro GB/Monat	0,055*	0,054*	0,09	0,075*	0,037*
Garantierte Verfügbarkeit in %	99,9	99,9	99,95	99,9	99,95
Datenverschlüsselung möglich	✓	✓	✓	✗	✓
Datenzugriff nach Vertragsende	✓	✗	✓	✗	✓
Mindestens ein Standort in der EU	✓	✓	✗	✓	✓
Nutzerseitiges Eigentumsrecht an den Daten	✓	✓	✗	✓	✓
Insolvenzfall geklärt	✗	✗	✗	✗	✗
Ja ✓ Nein ✗ *Angabe beschreibt niedrigst zu erreichenden Preis. Die Preise hängen von geografischer Region und genutztem Speicher- und Transfer-Volumen ab. Der Test wurde von November 2012 bis Juli 2013 durchgeführt. Ausführliche Informationen im Technischen Bericht Nr. 84, erschieden im Universitätsverlag Potsdam, ISBN 978-3-86956-274-2.					

Cost

Availability

Terms and Definitions



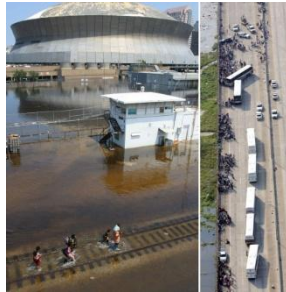
IT Security: Goals

- Security (general)
 - Describes a state without danger or the subjective impression that there is no danger.
 - Means that a subject or object, be it a person or a good, is protected from negative influences of a potential threat.
- Goals of IT security
 - Achieving and maintaining the defined security objectives.
 - e.g., to ensure the availability of data, services and applications, as well as to ensure the integrity and confidentiality of data.

Safety vs. Security

The following two aspects must be distinguished:

- (Operational/Functional) Safety



- Protection against negative consequences from legitimate actions.
 - accidental threats, nature
- Not primarily our topic.

- (Information) Security



- Protection against negative consequences from unauthorized actions.
 - intentional malice, human beings
- That's what this lecture is about.

IT Security: Important Terms

- Threat, Attack, Vulnerability
- Asset, Security Concept, Security Policy
- Security Control
- (Technical/Business) Impact
- Risk

The definitions of the terms are based on the following sources:

- Guide to Basic Protection based on IT-Grundschutz, BSI,
- ISACA Interactive Glossary & Term Translations, ISACA
- C. Eckert: IT-Sicherheit, Konzepte-Verfahren-Protokolle, Oldenbourg-Verlag

Threat

- Threat

- Anything (e.g., object, substance, human) that is capable of acting against an asset in a manner that can result in harm.
- A threat has a direct effect on an object as the result of a vulnerability.
- Examples:
 - Force majeure such as flooding is a threat to life and limb of people on the Oder.
 - Plague is a danger to life and limb, but currently not a threat (the plague pathogen is extinct)
 - Translated into the world of IT, a threat is a circumstance or event that can compromise the availability, integrity or confidentiality of information, thereby causing harm to the owner or user of the information.

- Threat agent

- Methods and things used to exploit a vulnerability.

Information Security Threats

- **Masquerade**
 - An entity claims to be another entity.
- **Eavesdropping**
 - An entity reads information it is not intended to read.
- **Authorization violation**
 - An entity uses a service or resources it is not intended to use.
- **Loss or Modification** of (transmitted) information
 - Data is being altered or destroyed.
- **Denial of Communication Acts (Repudiation)**
 - An entity falsely denies its participation in a communication act.
- **Forgery** of information
 - An entity creates new information in the name of another entity ("Man-in-the-Middle")
- **Sabotage**
 - An entity “destroys” resources.

Attack

- Attack
 - Unauthorized access or attempt to access an IT system or information.
 - Technical attacks can be divided into two categories:
 - passive attacks
 - aiming to obtain information (security objective confidentiality), e.g., eavesdropping on data lines
 - active attacks
 - aiming to change information (security objectives integrity and availability), e.g., faking a false identity in order to gain access to a system

Attacker Models

- Description of the attacker's abilities to carry out an attack.
- Examples: location, tools, cryptographic capabilities
- Purpose of an attacker model:
 - Development and evaluation of a security architecture.
 - What is to be protected? → Protected goods and security objectives
 - What motivation and skills does an attacker have? → attacker model
 - Example: Securing a house against vandals vs. professional burglars.
- Dolev-Yao attacker model: “classic” attacker model with the following attacker characteristics:
 - The attacker is omnipresent in the network and can eavesdrop on all messages.
 - The attacker is a participant in the network and can send his own messages.
 - The attacker can modify foreign messages.
 - Attackers CANNOT break the cryptography.
 - The attacker CANNOT compromise other participants, i.e. outsider attackers.
 - Alternative attacker model: Insider attacker can compromise systems.

Vulnerability

- Vulnerability
 - Weakness in the design, implementation, operation or internal control of a process that could expose the system to adverse threats from threat events.
 - A vulnerability may cause a threat to become effective and damage an organization or a system. As a result of a vulnerability an object (an organization or a system) is susceptible to threats.
 - Possible causes of vulnerabilities
 - conception and design
 - implementation
 - configuration
 - business
 - organization

Asset, Security Policy and Security Concept

- **Asset**
 - Assets refer to inventories of objects which are required for a specific purpose, in particular to meet business objectives. As a synonym for "asset" the term “value” is often used.
- **Security policy**
 - In a security policy the security objectives and general security requirements are formulated in the sense of the regulations of a company or a government agency. Detailed security controls (safeguards) are contained in a more comprehensive security concept.
- **Security concept**
 - A security concept serves to implement the security policy and describes the approach planned to achieve the security objectives set in an organization. It must be possible to trace every security control back to the respective security concept.

Security Control

- Security Control (Security Safeguard, Security Measure)
 - Device or protective measure that counteracts a hazard or neutralizes it. Prevents (excessive) damage to assets that would be caused by the occurrence of the scenario described in the hazard.
 - Security safeguards may serve to fulfil security requirements of a security concept.
 - Includes several categories:
 - organizational,
 - personnel,
 - technical or
 - infrastructural measures.
 - Example
 - Sufficiently high and solid dikes protect against flooding in the Oder area when the water level rises.

(Technical/Business) Impact

- Impact

- A deviation from an expected results leads to a consequence. As a matter of principle, this can be a positive or a negative deviation.
 - A positive impact within the meaning of the opportunity and risk analysis is also referred to as an opportunity.
 - In most cases, however, only the negative consequences, i.e. the damage, are considered in the risk analysis.

- Business impact

- The net effect, positive or negative, on the achievement of business objectives.

- Damage

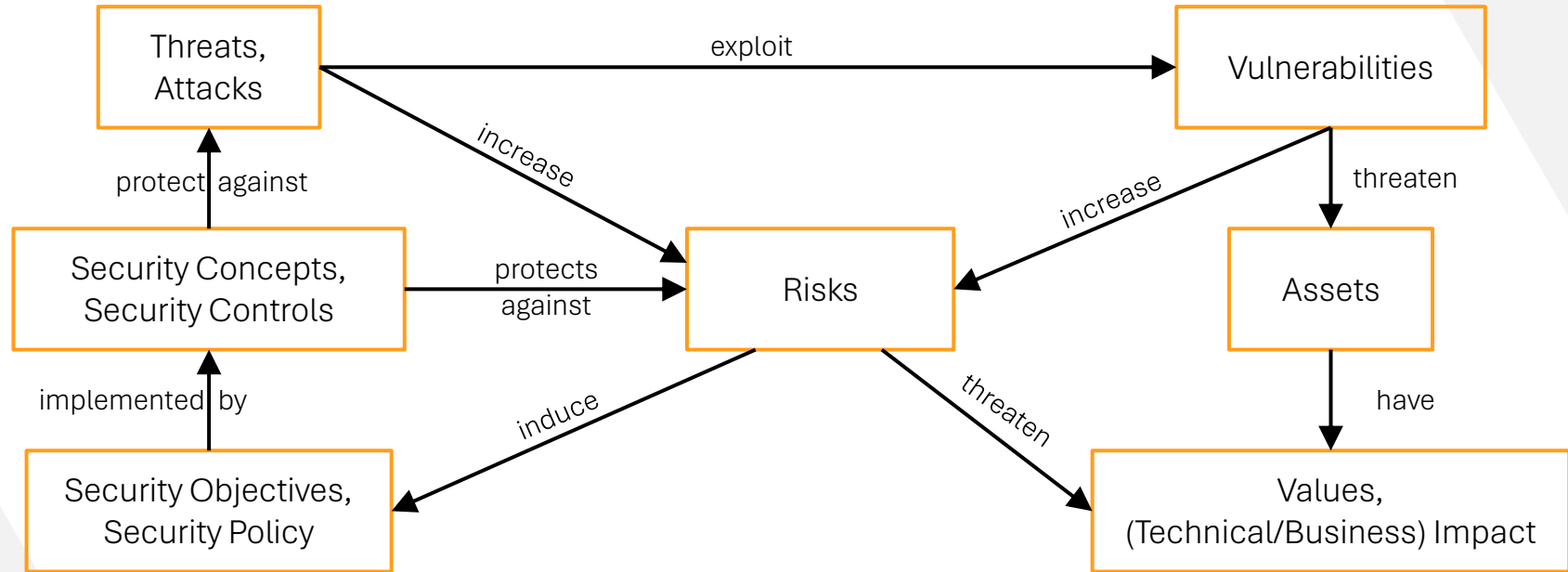
- Breaking the defined security objectives (successful attack on an IT system by exploiting a weak point) can cause various types of damage.
- Common damage scenarios:
 - violation of laws, regulations, contracts
 - impairment of the right to informational self-determination
 - impairment of personal integrity
 - impairment of task performance
 - negative internal or external impact
 - financial implications

Risk

- Risk

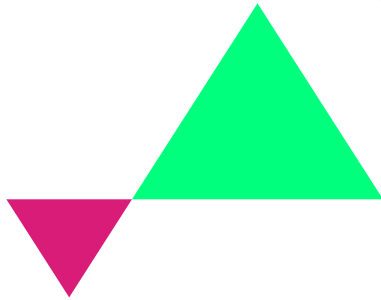
- A risk is the combination of the probability of occurrence of an event and its impact, based on the deviation from the set goal:
 - Risk = probability of occurrence * amount of damage
- The impact is often described as the difference between a planned and unplanned result. It can be negative (damage) or positive (opportunity).
- Determining the risks helps to prioritize the measures to be implemented.

Dependencies and Interrelations



[Based on: C. Eckert: IT-Sicherheit, Konzepte-Verfahren-Protokolle, Oldenbourg-Verlag]

Privacy and Data Protection



Protection Goal Privacy

- The right to privacy is anchored in human rights:
 - *„No one shall be subjected to arbitrary interference with his privacy, family, home or correspondence, ...” (1948).*
- A well-known definition comes from Louis D. Brandeis:
 - *„[Privacy is] The right to be left alone“ (1980)*
- The German Federal Constitutional Court (Bundesverfassungsgericht) defined the right to informational self-determination as
 - *„Befugnis des Einzelnen, grundsätzlich selbst über die Preisgabe und Verwendung seiner personenbezogenen Daten zu bestimmen“ (1983)*

Protection Goals Anonymity and Pseudonymity

- Anonymity
 - Personal data are changed in such a way that they **cannot** be assigned to a person or **only with disproportionate** effort.
- Pseudonymity
 - Personal data are changed in such a way that they can only be assigned to a person with knowledge of the **assignment rule** (which is only accessible to a **limited** group of people).

Differentiation between Anonymity and Pseudonymity

- Examples of anonymity
 - Aliases/*nicknames* in forums, chat rooms that do not require registration or do not collect any personal data.
- Examples of pseudonymity
 - Matriculation numbers
 - Aliases/*nicknames* in Internet services that require registration such as social networks, twitter, ebay, amazon (these collect personal data).



European General Data Protection Regulation (GDPR)

- Rules for the **processing of personal data** by private companies and public bodies
- **High fines:** up to EUR 20 million or 4% of the total annual turnover achieved worldwide
- Regulation enforced since 2018
- Basic principles and components, as in the previously valid German Federal Data Protection Act (BDSG)
 - **data avoidance, data economy, earmarking, technical and organizational measures (TOM)**
- **Personal data** (within the meaning of the GDPR) means
 - any information relating to an identified or identifiable natural person (**data subject**);
 - an **identifiable natural person** is one who can be identified,
 - directly or indirectly,
 - in particular by reference to an identifier such as a name, **an identification number, location data, an online identifier** or
 - to one or more factors specific to the **physical, physiological, genetic, mental, economic, cultural or social identity** of that natural person.

Security vs. Privacy

Data/information security
(German: “Datensicherheit”)



Data protection/privacy
(German: “Datenschutz”)

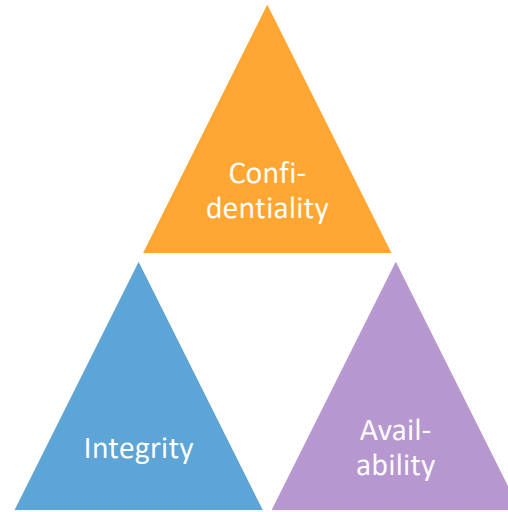
Protect data by **protecting**
information systems.

Protect human beings by
protecting their personal data.

Security and privacy can be conflicting or complementary objectives.

Security Objectives (aka Protection Goals)

- Principal security objectives :
 - Confidentiality
 - Integrity
 - Authenticity
 - Non-repudiation
 - Availability
- Protection goals regarding data protection
 - Privacy
 - Anonymity
 - Pseudonymity
 -



CIA triad of core security objectives

Examples: Security Goals in Application Environments

- **Banking and electronic trading**
 - Protect against fraudulent or accidental modification of transactions
 - Identify retail transaction customers
 - Protect corporate secrecy
 - Ensure customers privacy
 - Provide legally binding electronic signatures on transactions
- **Government**
 - Protect against disclosure of sensitive information
 - Provide electronic signatures on government documents
- **Public telecommunication providers**
 - Protect subscribers' privacy
 - Restrict access to administrative functions to authorized personnel
 - Protect against service interruptions
- **Corporate/private networks**
 - Protect corporate confidentiality / individual privacy
 - Ensure message authenticity
 - Protect against service interruptions
- **All networks**
 - Prevent outside penetrations (who wants hackers?)

Summary

- IT security considerations require knowledge of
 - communication model and abilities of the **attacker**
 - **security objectives**
 - CIA triad + authenticity & non-repudiation
 - privacy + anonymity & pseudonymity
 - **terms of IT security**
 - including threat and attack, vulnerability and protective measure, asset and risk
- Two aspects must be distinguished:
 - **safety** (operational safety) and
 - **security** (protection against undesired behavior)

